

The 5-Axis Maturity Model: Beyond Superficial Scoring

How NS-CMMF v1.0's Multi-Dimensional Assessment Approach Eliminates Paper Compliance and Produces Investment-Grade Maturity Intelligence

Published by Nucleus Systems • NS-CMMF v1.0 Market Introduction • Article 3 of 5 • 2026

The Nucleus Systems Cybersecurity Maturity Management Framework Version 1 (NS-CMMF v1.0) is the most comprehensive, consultable, and regulatory-aligned cybersecurity maturity framework available for mid-market and enterprise organizations operating across multiple jurisdictions. It reflects a fundamental modernization of traditional controls—re-engineered from legacy, static models to align with today's dynamic technologies, cloud-first architectures, and AI-driven operating environments. With 270 fully re-engineered and modernized controls, a 5-axis scoring model, and mapping to 32 frameworks and regulations, it replaces fragmented compliance checklists and opaque maturity ratings with a single, evidence-based instrument for measurement and continuous improvement.

A checklist asks, "Have you done this thing?" A framework asks: "How well are you doing this thing?"

The Single-Axis Illusion

The single-axis maturity model, in which a control receives a single score between L1 and L5 based on a holistic impression of its maturity, is simultaneously the most common and the most misleading approach to cybersecurity assessment. It is common because it is simple. It is misleading because security controls are not simple.

A real-world control has multiple distinct dimensions of quality. Consider an organization's incident response plan (IRP). The same IRP could be:

- Brilliantly designed (5/5) — comprehensive, role-specific, regulatory-notification-aware, with tested escalation paths
- Partially deployed (2/5) — only the IT security team has read it; HR, Legal, and Communications are unaware of their roles
- Never operationally exercised (1/5) — the plan has never been tested through a tabletop exercise or live incident
- Unmonitored (1/5) — there is no KPI tracking whether the plan is reviewed, updated, or rehearsed
- Entirely manual (1/5) — no automation, no playbook tooling, no automated notification capability

A single-axis assessment of this IRP would produce a composite score somewhere between 2 and 3, representing an 'average' of dimensions that should never be averaged. The organization believes it has adequate incident response capability. When an incident occurs, it is discovered that its technically well-designed IRP fails at the first step because the non-technical stakeholders who must execute it have never seen it.

The single-axis maturity model creates a category of 'paper security'; controls that score well because they are well-documented and well-designed, but that fail operationally because they are not consistently deployed, monitored, or automated. NS-CMMF v1.0's 5-axis model makes paper security impossible to hide.

The Five Dimensions of Real Security Maturity

The Nucleus Systems Cybersecurity Maturity Management Framework Version 1 (NS-CMMF v1.0) scores each of the 270 controls across five independent dimensions, each measuring a genuinely distinct aspect of control quality. The composite score is a weighted average, but the individual dimension scores are also preserved and visible, enabling an assessor to identify precisely where a control is strong and where it requires investment.

Dimension	Weight	What It Truly Measures	L3 Threshold (Minimum Acceptable Standard)
Design Adequacy	20%	Is the control well-designed for its intended purpose? Does it address the threat scenario it is designed to mitigate? Is it mapped to applicable regulatory obligations? Is the design reviewed and current?	Policy documented and reviewed within 12 months; regulatory mapping explicit; design addresses the specific threat scenario; approved by the appropriate authority
Implementation Coverage	25%	Is the control deployed across 100% of the in-scope population? Are exceptions formally documented with named owners and compensating controls? Is scope creep detected?	Coverage $\geq$ 95% of in-scope assets; exceptions formally documented with named owner and expiry; scope confirmed through automated discovery or equivalent
Operating Effectiveness	25%	Does the control operate consistently and reliably in production? Is there 3-month operational evidence? Are SLAs being met? Are exceptions managed through a formal process?	3-month operational evidence available; SLA adherence $\geq$ 95%; exceptions trigger formal exception process; no evidence of control bypassing or workarounds
Monitoring & Assurance	20%	Is the control independently tested and validated? Is its performance measured against defined KPIs or KRIs? Are exceptions escalated and tracked to resolution?	KPI or KRI defined and measured; annual independent test (internal audit, external assessment, or penetration test); exceptions trigger formal escalation; trend reporting active
Automation & Resilience	10%	Is the control automated, self-healing, and continuously evidenced? Would it continue to function effectively without manual intervention? Is evidence generated automatically?	Partial automation of evidence generation; alert on control failure; some self-healing capability; evidence does not rely entirely on manual collection

The composite score formula, $\text{Design} \times 0.20 + \text{Coverage} \times 0.25 + \text{Operating} \times 0.25 + \text{Monitoring} \times 0.20 + \text{Automation} \times 0.10$, weights operational effectiveness and coverage most heavily. This reflects a fundamental principle: a control that actually runs and is actually deployed to 100% of the in-scope population is more valuable than a control that is brilliantly designed but only partially deployed. Implementation and operation are necessary conditions for security; design is not sufficient.

The Seven Hard Scoring Gates: Non-Negotiable Ceilings

In addition to the five-dimensional composite score, The Nucleus Systems Cybersecurity Maturity Management Framework Version 1 (NS-CMMF v1.0) applies seven hard scoring gates—ceiling constraints that prevent any composite score from exceeding a defined level regardless of how the five dimensions score. These gates reflect a fundamental principle: certain minimum conditions must be met before any maturity claim is credible.

Hard gates cannot be overridden by compensating controls, documentation, or management override. They are binary: the condition is either met or not.

Hard Gate	Ceiling Applied	Why This Gate Exists
No documented owner	Maximum L2	An unowned control is a policy statement, not an operational control. Without named accountability, the control will degrade toward L1 as soon as organizational attention shifts. Personal accountability is the minimum condition for sustained security.
No operational evidence over 3-month sample	Maximum L3	A control that cannot demonstrate consistent operation over 3 months may be functioning at the time of assessment, but has no evidence of sustained operation. Point-in-time 'show' evidence does not demonstrate programme maturity.
No KPI or KRI defined	Maximum L4	A control that cannot be measured cannot be managed. Without a defined performance indicator, degradation is invisible until failure. KPI definition is the minimum condition for managed maturity.
No automated telemetry or independent assurance	Maximum L5	Level 5 requires a control to be self-sustaining, continuously evidenced, and independently verified. Manual processes and self-reported evidence cannot support an L5 claim.
Regulatory obligation demonstrably unmet	Maximum L2 / High Risk	Good documentation does not compensate for regulatory non-compliance. If a control is designed to satisfy a specific regulatory obligation and that obligation is verifiably unmet, the control cannot score above L2 regardless of its design quality.
Interview-only evidence (Tier 3)	Maximum L2 / Unverified	Verbal assertions without corroborating documentation are the lowest-quality evidence source. Unverifiable claims cannot support maturity above L2.
Attestation-only evidence (Tier 4)	Maximum L1.5 / Unverified	Management attestation without documentary or technical evidence is insufficient for any maturity claim above L1.5. The financial cost of attestation-only scoring has been demonstrated repeatedly in regulatory investigations.

The Result: Investment-Grade Maturity Intelligence

The combination of five-dimensional scoring and seven hard gates produces a maturity assessment that has three properties that conventional assessments cannot claim:

Board-Ready An NS-CMMF v1.0 score is defensible before a board audit committee because it is based on specific, documented evidence at the control level. A board member who asks How do we know this control is	Investment-Grade The 5-axis scoring model enables financial quantification of the gap between current and target maturity. The 'cyber debt' concept, the cost to bring all controls to a minimum L3 baseline, is
--	--

actually working?' can be directed to the specific 3-month operational evidence, the KPI trend report, and the independent test result, not to a traffic-light dashboard.

Audit-Ready

An NS-CMMF v1.0 assessment produces a pre-structured evidence base for every control that maps to every applicable regulatory framework. When a regulator requests evidence of DORA ICT risk management capability, the evidence package for all DORA-mapped controls is immediately available because it was assembled during the assessment process, not reconstructed under time pressure during a regulatory examination.

calculated from the dimension-level gaps across all 270 controls. This produces a financial figure (CAPEX + Year 1 OPEX) that investment committees, private equity operating partners, and CFOs can incorporate directly into capital allocation decisions.

Continuously Improvable

Because each dimension is scored independently, the roadmap is automatically prioritized by the highest-impact gaps across dimensions. An organization whose controls score well on Design but poorly on Coverage knows exactly where to invest: deployment, not design. An organization scoring well on Coverage but poorly on Monitoring knows that its investment should go to KPI infrastructure and independent testing, not further deployment.

NS-CMMF v1.0's 5-axis model doesn't just produce a better score—it produces a fundamentally different kind of output. Instead of a maturity rating, it produces a precision roadmap: specific, dimension-level gaps across 270 controls, prioritized by business risk impact and translated into financial investment requirements.